PRODUCT DESCRIPTION (PD)
DEPARTMENT OF VETERANS AFFAIRS

Veterans Health Administration
Employee Experience and Workforce Development
Orlando VA Medical Center

Brand Name or Equal Qualtrics Survey Services
and Brand Name or Equal Sestek Virtual Agent

Date: November 3, 2026
VA-26-00082605
PD Version Number: 1.2

1.0 PRODUCT REQUIREMENTS

The Department of Veterans Affairs (VA), Veterans Health Administration (VHA), Orlando VA Healthcare System (HCS) has a requirement for an integrated digital experience solution. The supplies and services to be procured are an integrated digital experience solution delivered as a managed cloud service within an approved Federal Risk and Authorization Management Program (FedRAMP) authorized environment. Additionally, the integrated virtual-agent software shall provide the Orlando VA HCS with licensing, implementation, integration, and technical-account-management services to enhance Veteran self-service and related support functions. The Contractor shall provide a brand name or equal Qualtrics, FedRAMP-authorized platform and overall program management. The Contractor shall also provide a brand name or equal Sestek virtual agent that includes software licenses and hosting, implementation and integration services, technical account management, and ongoing support.

The Contractor shall implement and integrate the integrated solution with the brand name or equal Qualtrics EX platform, VA-Orlando-designed systems, and required third-party application programming interfaces (APIs). The Contractor shall provide dedicated technical-account-management services and ongoing support under a five-by-eight (5x8) Service-Level Agreement (SLA) and shall provide up to one billion brand name or equal OpenAI Large Language Model (LLM) tokens per contract year. The Contractor shall also provide Qualtrics-hosted FedRAMP-supported survey operations conducted through the Qualtrics environment that are consistent with the security and incident-reporting postures to include sample provision, respondent remuneration and redemption tracking, comma-separated values (CSV) data delivery, and regular reporting, as applicable to the approved scope. The integrated solution shall support up to 5,400 Orlando VA HCS users and employees. Performance and delivery shall be remote and conducted from within the approved FedRAMP-authorized boundary.

1.1 PERIOD OF PERFORMANCE

The period of performance shall include one 12-month base period and four (4) 12-month option periods, if exercised

1.2 BRAND NAME OR EQUIVALENT REQUIREMENTS

The following table contains the brand name products that the VA knows would meet the below salient characteristics (see Section 1.2). Should the Offeror propose “or equivalent” products, the Offeror shall demonstrate that the proposed product(s) meets the salient characteristics detailed in Sections 1.2.

Brand Name or Equal Qualtrics Platform & Brand Name or Qual Sestek Virtual Agent Requirements			
Base Period			
Part Number	**OEM**	**Description**	**QTY**

510458-611	Qualtrics	FedRAMP EX Foundational Per Employee Tier 5001 - 10,000 Employees, 1 Year Term	5,400
CON	Qualtrics	Employee Experience (EX) Program Implementation	1
N/A	Sestek	Sestek KnowVU Virtual Agent - software license, hosting, implementation / integration (operates within Qualtrics FedRAMP boundary)	1
Option Period One			
Part Number	**OEM**	**Description**	**QTY**
510458-611	Qualtrics	FedRAMP EX Foundational Per Employee Tier 5001 - 10,000 Employees, 1 Year Term	5,400
N/A	Sestek	Sestek KnowVU Virtual Agent - software license, hosting, implementation / integration (operates within Qualtrics FedRAMP boundary)	1
Option Period Two			
Part Number	**OEM**	**Description**	**QTY**
510458-611	Qualtrics	FedRAMP EX Foundational Per Employee Tier 5001 - 10,000 Employees, 1 Year Term	5,400
N/A	Sestek	Sestek KnowVU Virtual Agent - software license, hosting, implementation / integration (operates within Qualtrics FedRAMP boundary)	1
Option Period Three			
Part Number	**OEM**	**Description**	**QTY**
510458-611	Qualtrics	FedRAMP EX Foundational Per Employee Tier 5001 - 10,000 Employees, 1 Year Term	5,400
N/A	Sestek	Sestek KnowVU Virtual Agent - software license, hosting, implementation / integration (operates within Qualtrics FedRAMP boundary)	1
Option Period Four			
Part Number	**OEM**	**Description**	**QTY**
510458-611	Qualtrics	FedRAMP EX Foundational Per Employee Tier 5001 - 10,000 Employees, 1 Year Term	5,400
N/A	Sestek	Sestek KnowVU Virtual Agent - software license, hosting, implementation /	1

DRAFT

		integration (operates within Qualtrics FedRAMP boundary)	

1.3 SALIENT CHARACTERISTICS

The Contractor's integrated digital solution shall demonstrate the following salient characteristics at the time of award. If proposing an "or equal" integrated digital solution, please ensure it meets all salient characteristics provided below.

The Contractor's software integrated digital solution shall demonstrate the following salient characteristics:

1. Brand name or equal FedRAMP authorized platform services operating within a brand name or equal Qualtrics approved secure environment
2. Brand name or equal Sestek cloud based Knovvu Virtual Agent capability operating within the brand name or equal Qualtrics approved FedRAMP authorized boundary
3. Software licenses and hosting for up to 5,400 Orlando VA HCS users/employees
4. Implementation and integration services connecting the Virtual Agent with the brand name or equal Qualtrics EX platform, VA Orlando designed systems, and required third party APIs
5. Survey-related support including sample/panel provision, respondent remuneration management, redemption tracking, CSV data delivery, and monthly reporting, as applicable to the approved scope
6. Dedicated technical account management
7. Ongoing support and maintenance under a 5x8 SLA
8. Capacity for up to 1,000,000,000 (one billion) OpenAI or equivalent large language model tokens per contract year
9. Encrypted transmission of all VA data using VA-approved cryptographic modules
10. Prohibition on transmission or storage of VA data outside the approved FedRAMP-authorized boundary
11. Prohibition on disclosure, transmission, or storage of PII, PHI, or other patient/employee identifying information except as expressly authorized
12. Remote performance and delivery consistent with the security boundaries defined in this PD

2.0 SaaS FEDRAMP ASSESSMENT AND AUTHORIZATION AND CONTINUOUS MONITORING REQUIREMENTS

2.1 IF THE SOLUTION IS NOT FEDRAMP AUTHORIZED:

1. The information system solution selected by the Contractor shall comply with the Federal Information Security Management Act (FISMA).
2. The Contractor shall comply with FedRAMP requirements at the <<Insert Impact Level from the Data Security Categorization. This should be done by DTC>> Impact Level, as mandated by Federal laws and policies,

including making available any documentation, physical access, and logical access needed to support this requirement.

3. The Contractor shall provide a SaaS product as defined by the following criteria: Software as a Service (SaaS) is an application delivery model in which the application is hosted on a cloud infrastructure outside the security boundary of VA and is provided to the Cloud Service Customer (CSC) over the internet. The CSC uses the SaaS offering via a thin-client interface, such as a web-browser or a program interface. The CSC subscribes to the SaaS offering and is only responsible for minor in-app customizations. The Cloud Service Provider (CSP) offering the application is responsible for management of the application, safeguarding of data stored or processed by the application, and all elements of the underlying infrastructure. Additionally, the CSP is responsible for all on-going compliance. In order to qualify as SaaS for use at VA, and to align with Federal Risk and Authorization Management Program (FedRAMP) requirements, the hosting for the offering must conform to the NIST 800-145 definition of Cloud Computing and thus contain following key characteristics:
    - *On-Demand Self-Service*: The CSP fully automates the provisioning of both the customer interface and the underlying cloud components of the SaaS offering. In some cases, to the CSP may provision internal resources manually, while providing the CSC an automated interface to request and track the service.
    - *Broad Network Access*: The SaaS capabilities are available over the internet or over a network that is available from all access points the CSC requires. The SaaS offering is accessible through common platforms (e.g., mobile phones, tablets, laptops, and workstations).
    - *Resource Pooling*: The computing infrastructure supporting the SaaS offering is shared among more than one CSC using a multi-tenant model, and resources are dynamically assigned depending on customer demand.
    - *Rapid Elasticity*: Computing capabilities are automatically provisioned and released in a manner that scales with customer demand. In some cases, the scaling of resources may not be fully automated, but it should be fast enough to support the needs of the CSC, which the CSC would have to define.
    - *Measured Service*: Resource usage, such as storage, processing, bandwidth, and user activity are measured and reported on in a manner that is relevant to the SaaS offering.
4. Following guidance from the Federal CIO, VA will utilize existing JAB ATO or agency ATO issued by another agency as a starting point for

FedRAMP requirements. If neither of those exist, VA will sponsor The Cloud Service Provider for a FedRAMP Authorization. VA will be using the FedRAMP baselines as a starting point, since they are specifically tailored for cloud services.

5. The Contractor shall, where applicable, assist with the VA ATO Process to help achieve agency authorization of the cloud service or migrated application at the impact level required by VA to utilize the product. For this solution the required impact level is: <<Insert Impact Level from the Data Security Categorization. This should be done by DTC>>.
6. The Contractor shall comply with FedRAMP requirements surrounding data location within the Continental United States. FedRAMP specifies data location requirements in the High Baseline as part of control SA-9 (5); however, FedRAMP does not provide or specify data location requirements for other baselines.
7. The Contractor shall complete a FedRAMP System Security Plan (SSP) and supporting documentation including required attachments.
8. The Contractor shall work with a VA DTC Subject Matter Expert to develop and provide a VA system boundary diagram including any integration and connectivity components for VA use. This will be known as the VA Implementation Diagram (VAID) and will demonstrate the proposed implementation of this system at VA.
9. The Contractor shall complete a Third-Party Assessment Organization (3PAO) Security Assessment Plan (SAP).
10. The Contractor shall complete a 3PAO Security Assessment Report (SAR).
11. If new or unanticipated vulnerabilities are discovered by either VA or the Contractor, or if existing safeguards have ceased to function, the discoverer shall bring the situation to the attention of the other party within one hour in accordance with Addendum B, VA Information and Information System Security/Privacy Language.
12. The Contractor shall comply with FedRAMP data management requirements.
13. Successful issuance of a VA ATO will be required before live VA data can be used in the system.
14. The Contractor shall participate in FedRAMP Continuous Monitoring activities as outlined by FedRAMP's Continuous Monitoring Strategy Guide found on the FedRAMP website.
15. The Contractor shall participate in monthly Agency and FedRAMP Sustainment meetings following the granting of a VA ATO.
16. The Contractor shall provide continuous monitoring activities including, but not limited to, scans, security artifacts, and provide Continuous Monitoring Monthly Scans and monthly Plan of Action and Milestones (POAM) reports as outlined by VA and FedRAMP requirements.
17. The Contractor shall provide a Monthly VA License Report of VA sites currently utilizing the cloud product post ATO award. The license report shall include the number of subscription licenses being utilized and the specific VA site where they're in use.

Deliverables:

A. FedRAMP System Security Plan (SSP) and required Attachments
B. VA Implementation Diagram
C. 3PAO Security Assessment Plan (SAP)
D. 3PAO Security Assessment Report (SAR)
E. Plan of Action and Milestones Reports.
F. Monthly VA License Report

2.2 IF THE SOLUTION IS FEDRAMP AUTHORIZED BUT NOT VA AUTHORIZED:

1. The information system solution selected by the Contractor shall comply with the Federal Information Security Management Act (FISMA)
2. The Contractor shall remain in compliance with FedRAMP requirements as mandated by Federal laws and policies, including making available any documentation, physical access, and logical access needed to support this requirement.
3. The system must be FedRAMP Authorized at no less than the <<Insert Impact Level from the Data Security Categorization. This should be done by DTC>>
4. The Contractor shall, where applicable, assist with the VA ATO Process to help achieve agency authorization of the cloud service or migrated application.
5. The Contractor shall provide confirmation of the completion of its FedRAMP System Security Plan (SSP) and supporting documentation by providing, to the VA PM, COR, and DTC, its repository ID number and associated link for VA to download the SSP and all required artifacts within five calendar days of contract award.
6. The Contractor shall work with a VA DTC Subject Matter Expert to develop and provide a VA specific system boundary diagram including any integration and connectivity components for VA use. This will be known as the VA Implementation Diagram (VAID) and will demonstrate the proposed implementation of this system at VA.
7. The Contractor shall provide the results of their most recent Third-Party Assessment Organization (3PAO) Security Assessment Plan (SAP).
8. The Contractor shall complete a 3PAO Security Assessment Report (SAR).
9. The Contractor shall provide VA with the most recent monthly scans for the production environment within the authorization boundary and their scan upload schedule for FedRAMP within 30 calendar days of contract award.
10. The Contractor shall provide their availability to participate in monthly continuous monitoring meetings to be scheduled following successful VA ATO within 30 calendar days of contract award.

DRAFT

11. If new or unanticipated vulnerabilities are discovered by either VA or the Contractor, or if existing safeguards have ceased to function, the discoverer shall

    bring the situation to the attention of the other party within one hour in accordance with Addendum B, VA Information and Information System Security/Privacy Language.
12. The Contractor shall comply with FedRAMP data management requirements.
13. Successful issuance of a VA ATO will be required before live VA data can be used in the system.
14. The Contractor shall participate in FedRAMP Continuous Monitoring activities as
    outlined by FedRAMP's Continuous Monitoring Strategy.
15. The Contractor shall participate in monthly Agency and FedRAMP Sustainment meetings following the granting of a VA ATO.
16. The Contractor shall provide continuous monitoring activities including, but not limited to scans, security artifacts, and provide Continuous Monitoring Monthly Scans and monthly Plan of Action and Milestones (POAM) reports as outlined by VA and FedRAMP requirements.
17. The Contractor shall provide a Monthly VA License Report of VA sites currently utilizing the cloud product post ATO award. The license report shall include the number of subscription licenses being utilized and the specific VA site where they're in use.

Deliverables:

A. VA Implementation Diagram
B. 3PAO Security Assessment Plan (SAP)
C. 3PAO Security Assessment Report (SAR)
D. Plan of Action and Milestones Reports
E. Monthly VA License Report

2.3 IF THE SOLUTION IS FEDRAMP AUTHORIZED AND VA AUTHORIZED:

1. The information system solution selected by the Contractor shall comply with the Federal Information Security Management Act (FISMA) and have a current VA authorization.
2. The Contractor shall remain in compliance with FedRAMP requirements as mandated by Federal laws and policies, including making available any documentation, physical access, and logical access needed to support this requirement.
3. The FedRAMP Authorization level and existing VA ATO should be no less than the level required for this use case which has been defined as <<Insert Impact Level from the Data Security Categorization. This should be done by DTC>>.
4. The Contractor shall, where applicable, assist with the VA ATO Sustainment Process to help maintain health and quality of agency

authorization of the cloud service or migrated application.

5. The Contractor shall exclusively provide subscription licenses to FedRAMP authorized and VA authorized environments.
6. If new or unanticipated vulnerabilities are discovered by either VA or the Contractor, or if existing safeguards have ceased to function, the discoverer shall bring the situation to the attention of the other party within one hour in

   accordance with Addendum B, VA Information and Information System Security/Privacy Language. VA Privacy and Security deliverables as directed by the VA System owner.
7. The Contractor shall comply with FedRAMP data management requirements.
8. Successful issuance of a VA ATO will be required before live VA data can be used in the system.
9. The Contractor shall participate in FedRAMP Continuous Monitoring activities as outlined by FedRAMP's Continuous Monitoring Strategy Guide found on the FedRAMP Website.
10. The Contractor shall provide continuous monitoring activities including, but not limited to, scans, security artifacts, and provide Continuous Monitoring Monthly Scans and monthly Plan of Action and Milestones (POAM) reports as outlined by FedRAMP requirements.
11. The Contractor shall participate in monthly Agency and FedRAMP Sustainment meetings following the granting of a VA ATO.
12. The Contractor shall provide a Monthly VA License report of VA sites currently utilizing the cloud product post ATO award. The license report shall include the number of subscription licenses being utilized and the specific VA site where they're in use.

Deliverables:

A. Continuous Monitoring Monthly Scans
B. Plan of Action and Milestones Reports.
C. Monthly VA License Report

3.0 NOTICE OF THE FEDERAL ACCESSIBILITY LAW AFFECTING ALL INFORMATION AND COMMUNICATION TECHNOLOGY (ICT) PROCUREMENTS (SECTION 508)

On January 18, 2017, the Access Board issued a final rule that updated accessibility requirements covered by Section 508 and refreshed guidelines for telecommunications equipment subject to Section 255 of the Communications Act. The final rule went into effect on January 18, 2018. The revisions and updates to the Section 508-based standards and Section 255-based guidelines are intended to ensure that information and communication technology (ICT) covered by the respective statutes is accessible to and usable by individuals with disabilities.

3.1 SECTION 508 – INFORMATION AND COMMUNICATION TECHNOLOGY (ICT) STANDARDS

The Section 508 standards established by the Access Board are incorporated into, and made part of all VA orders, solicitations and purchase orders developed to procure ICT. These standards are found in their entirety at: Revised 508 Standards and 255 Guidelines (access-board.gov). A single PDF file version of the Revised Section 508 Standards and 255 Guidelines will be supplied upon request, or can be obtained from the Access Board website. Federal agencies must comply with the Rehabilitation Act of 1973, as amended.

The Contractor shall comply with "508 Chapter 2: Scoping Requirements" for all electronic ICT and content delivered under this contract. Specifically, as appropriate for the technology and its functionality, the Contractor shall comply with the technical standards marked here:

- ☒ E205 Electronic Content – (Accessibility Standard -WCAG 2.0 Level A and AA Guidelines)
- ☒ E204 Functional Performance Criteria
- ☐ E206 Hardware Requirements
- ☒ E207 Software Requirements
- ☒ E208 Support Documentation and Services Requirements

3.2 COMPATABILITY WITH ASSISTIVE TECHNOLOGY

The standards do not require installation of specific accessibility-related software or attachment of an assistive technology device. Section 508 requires that ICT be compatible with such software and devices so that ICT can be accessible to and usable by individuals using assistive technology, including but not limited to screen readers, screen magnifiers, and speech recognition software.

3.3 ACCEPTANCE AND ACCEPTANCE TESTING

Deliverables resulting from this solicitation will be accepted based in part on satisfaction of the Section 508 Chapter 2: Scoping Requirements standards identified above.

The Government reserves the right to test for Section 508 Compliance before delivery. The Contractor shall be able to demonstrate Section 508 Compliance upon delivery.

4.0 INFORMATION TECHNOLOGY USING SUSTAINABLE PRODUCTS

Not Applicable

5.0 ELECTRONIC DELIVERY OF THE INTEGRATED DIGITAL EXPERIENCE SOLUTION – FELICA.NEWSOME-DENT@VA.GOV

Inspection: Destination
Acceptance: Destination
Free on Board (FOB): Destination

Ship To and Mark For:

Primary		Alternate	
Name:	Felica Newsome-Dent	Name:	
Address:	13800 Veterans Way Orlando, FL 32827	Address:	
Phone:	407-403-3563		
Email:	Felica.Newsome-Dent@va.gov	Email:	

6.0 GENERAL REQUIREMENTS

6.1 VA TECHNICAL REFERENCE MODEL

The Contractor shall comply with the VA OIT Technical Reference Model (VA TRM). Compliance with the VA TRM is achieved by using only technologies and standards that are listed as approved for use in the VA TRM. The Contractor shall provide all necessary information requested by VA to ensure TRM approval is obtained prior to use on VA's network.

6.2 ZERO TRUST – VA CRITICAL SECURITY CONTROLS

VA has established minimum mandatory security requirements and requires that any network connected software system or service must meet the VA Critical Security Controls as outlined in the VA Memorandum, "VA Security Controls", https://www.voa.va.gov/DocumentView.aspx?DocumentID=5010. VA Critical Security Controls identify the minimum mandatory requirements that must be implemented across all VA enterprise infrastructure, cloud computing environments, information systems, networks, and specialized devices (medical devices/systems, special-purpose systems, and research scientific computing devices) that process, store, and/or transmit VA data. Effective July 1, 2025, the Contractor shall implement these VA Critical Security Controls, within any network connected software system or service prior to being authorized for use in the VA. This functional requirement is not negotiable, and Plan of Action & Milestones (POAM) will not be accepted in the event these controls cannot be implemented for new systems. Critical Security Controls are intended to increase VA's security posture and provide security and privacy risk visibility into the VA network and is not a new requirement. The Contractor's failure to maintain these VA Critical Controls after implementation will result in VA discontinuing the use of the system.

6.3 SOCIAL SECURITY NUMBER (SSN) REDUCTION

The Contractor solution shall support the Social Security Number (SSN) Fraud Prevention Act (FPA) of 2017 which prohibits the inclusion of SSNs on any document sent by mail. The Contractor support shall also be performed in accordance with Section 240 of the Consolidated Appropriations Act (CAA) 2018, enacted March 23, 2018, which mandates VA to discontinue using SSNs to identify individuals in all VA information systems as the Primary Identifier. The Contractor shall ensure that any new IT solution discontinues the use of SSN as the Primary Identifier to replace the SSN with the Integrated Control Number (ICN) in all VA information systems for all individuals. The Contractor shall ensure that all Contractor delivered applications and systems integrate with the VA Master Person Index (MPI) for identity traits to include the use of the ICN as the Primary Identifier. The Contractor solution may only use a Social Security Number to identify an individual in an information system if and only if the use of such number is required to obtain information VA requires from an information system that is not under the jurisdiction of VA.

6.4 INTERNET PROTOCOL VERSION 6 (IPV6)

The Contractor solution shall support IPv6-Only based upon the memo issued by the Office of Management and Budget (OMB) on November 19, 2020 (https://www.whitehouse.gov/wp-content/uploads/2020/11/M-21-07.pdf). Which defines IPv6-only as the state of an operational system or service when IPv4 protocol functions (addressing, packet forwarding) are not in use. The NIST USGv6 profile defines technical requirements for a product to be capable of operating in IPv6-Only environments. IPv6-Only technology, in accordance with the USGv6 Program (https://www.nist.gov/programs-projects/usgv6-program/usgv6-revision-1), NIST Special Publication (SP) 500-267B Revision 1 “USGv6 Profile” (https://doi.org/10.6028/NIST.SP.500-267Br1), and NIST SP 800-119 “Guidelines for the Secure Deployment of IPv6” (https://doi.org/10.6028/NIST.SP.800-119), compliance shall be included in all IT infrastructures, application designs, application development, operational systems and sub-systems, and their integration. In addition to the above requirements, all devices, applications, and systems shall support all applicable functionality on native IPv6-Only as well as dual stack (IPv6 / IPv4) connectivity without additional memory or other resources being provided by the Government, so that they can function in a mixed environment. All public/external facing servers and services (e.g., web, email, DNS, ISP services, etc.) shall support native IPv6-Only and dual stack (IPv6 / IPv4) users and all internal infrastructure and applications shall support using native IPv6-Only and dual stack (IPv6 / IPv4) for all functionality and operations.

6.5 SOFTWARE AND LICENSING REQUIREMENTS

The Contractor shall be responsible for the provision of all software licenses and any associated licensing maintenance required for any development, delivery, integration, operation, and/or maintenance associated with its proposed application(s), software products, software solution, and/or system including, but not limited to, any and all application(s), software and/or software products that comprise, are a part of, or

integrate with the Contractor's proposed application(s), software products, software solution, and/or system for the life of any resulting contract.

6.6 TRUSTED INTERNET CONNECTION (TIC)

The Contractor solution shall meet the requirements outlined in Office of Management and Budget Memorandum M-19-26, "Update to the Trusted Internet Connections (TIC) Initiative" (https://www.whitehouse.gov/wp-content/uploads/2019/09/M-19-26.pdf), VA Directive 6513 "Secure External Connections", and shall comply with the TIC 3.0 Core Guidance Documents, including all Volumes and TIC Use Cases, found at the Cybersecurity & Infrastructure Security Agency (CISA) (https://www.cisa.gov/publication/tic-30-core-guidance-documents.)

6.7 GENERATIVE ARTIFICIAL INTELLIGENCE REQUIREMENTS

If Artificial Intelligence (AI) is part of the Contractor system/solution, the Contractor shall be in compliance with E.O. 13960 and 14319, OMB Memorandums M-25-21, M-25-22, and M-26-04, and VA Directive and Handbook 6500 to support VA in trustworthy, secure, responsible, accountable, Truth Seeking, and Ideologically Neutral AI innovation.

No web-based, publicly available generative AI service has been approved for use with VA-sensitive data including, but not limited to OpenAI's ChatGPT, Microsoft's Copilot, Google's Gemini, and Anthropic's Claude. No PII, protected health information (PHI), or VA-sensitive data should be entered into these unapproved services. The entire definition of VA Sensitive Data can be found at 38 U.S.C. § 5727 (23). The Contractor shall protect VA Sensitive data from unauthorized disclosure or use, and from being used to train or improve the functionality of the vendor's commercial offerings without express permission from VA. Only VA-hosted instances of generative AI services may be approved for use with VA-sensitive data.

The Contractor shall deliver the services, technical data, configurations, models, weights, documentation or other information, including source code, developed during contract performance. The Contractor, in collaboration with VA, must evaluate the output of any AI tool for accuracy prior to using the output in VA efforts. All data, including models, weights, algorithms, and outputs generated using either Government-furnished data or data first developed under this contract shall be the property of the Government with unlimited rights as defined by FAR 52.227-14. The Contractor shall also deliver any custom-developed code developed with AI methodologies in accordance with the SHARE IT Act, if applicable. VA shall also retain unlimited rights to any improvements to that data, including the continued design, development, testing, and operation of AI systems and/or systems utilizing AI.

The Contractor shall ensure that all AI Systems, including Large Language Models (LLM), whether standalone LLMs or integrated into broader software platforms, procured under this effort and/or used in performance of this contract complies with the

Unbiased AI Principles as defined in Executive Order 14319 and OMB Memorandum M-26-04, e.g. Truth Seeking and Ideologically Neutral, as applicable to the intended use of the system.

The Contractor shall ensure that AI System/LLM generated outputs are truthful in responding to user prompts seeking factual information or analysis, prioritize historical accuracy, scientific inquiry, and objectivity, as well as acknowledge uncertainty where reliable information is incomplete or contradictory and do not fabricate, hallucinate, or present unverifiable information as fact.

The Contractor shall ensure that LLMs and AI outputs are neutral, nonpartisan tools that do not manipulate responses in favor of ideological dogmas such as Diversity, Equity, and Inclusion (DEI). The Contractor shall ensure that the LLMs, including the AI System, are not intentionally encoded with partisan or ideological judgments within an AI System's/LLM's outputs unless those judgments are prompted by or otherwise readily accessible to the end user.

Compliance with the AI requirements of this contract, including adherence to the Unbiased AI Principles, Truth-Seeking and Ideological Neutrality requirements, disclosure obligations, monitoring and reporting requirements, and corrective action responsibilities, is a material condition of eligibility for payment and continued performance. In accordance with OMB Memorandum M-26-04, failure to comply with these requirements, or refusal to take timely and appropriate corrective action to remedy identified noncompliance, may constitute a material breach of contract and may result in remedies consistent with the terms of the contract and applicable law including but not limited to withholding of payment, termination for cause/default, or other appropriate contractual remedies, as determined by the Contracting Officer.

All AI for delivery and/or use in performance of the contract shall adhere to the *VA Trustworthy AI Framework*, available at https://department.va.gov/ai/trustworthy/. Once the Contractor has obtained CO authorization to use specific AI in contract performance, the Contractor shall provide the COR a signed Statement of Attestation prior to AI implementation as identified in the Artificial Intelligence in VA Contracts clause, to include its associated list of AI being used in contract performance.

Deliverable:

A. Statement of Attestation

6.7.1 AI SYSTEM/LLM DEVELOPMENT AND OPERATION DOCUMENTATION REQUIREMENTS

To enable Government continued assessment of compliance with Trustworthy AI requirements and both Unbiased AI Principles, Truth-seeking and Ideological Neutrality,

in accordance with OMB M-26-04, the Contractor shall provide AI System/LLM Development and Operation Documentation Package to include, at a minimum:

1. **Acceptable Use Policy**

The Contractor shall provide an Acceptable Use Policy document governing its AI operation that characterizes and differentiates appropriate and inappropriate use of their product offering

2. **Model Cards, System Cards and/or Data Cards**

The Contractor shall provide documentation describing essential information about the model, system, and or data as it relates to the AI/LLM product offering. The documentation shall address summaries of training process, identified risks and mitigations, and model evaluation scores on LLM benchmarks at a minimum, where appropriate

3. **End User Resources**

The Contractor shall provide documentation to include product tutorials, developer guides, and/or other tools to assist VA in ensuring proper use of the AI/LLM to maximize utility

4. **Mechanism for End User Feedback**

The Contractor shall provide documentation describing the mechanism employed to provide feedback to the Offeror on outputs identified that violate the Unbiased AI Principles. This may be satisfied by a general inbox, specific Point of Contact, or similar feedback mechanism.

5. **Pre-Training and Post-Training Activities of the AI System/LLM**

The Contractor shall provide documentation of Pre-Training and Post Training Activity that provides details on:

a. Actions taken that impact the factuality and grounding of AI System/LLM outputs

b. System-level prompts that provide natural language instructions to the model specifying guidelines on responding to user-generated queries, to include how a model responds when reliable information is incomplete, contradictory, or subject to individual interpretation

c. The type of outputs restricted via content moderation and safety filters

d. The use of red teaming as a means of continuously assessing the model to protect against incidents of bias in generated output.

e. Training or development, if any, that occurred outside the United States, to include the type of activity and the country in which it occurred.

f. Any modifications or configurations undertaken to comply with any regulation from a government other than the U.S. Federal Government.

6. **Model Evaluation Results and Methodologies**

   The Contractor shall provide documentation describing the Evaluation Results of bias evaluations conducted by the Vendor to include the methodology for performing such tests (e.g., testing prompt pairs for politically oriented topics).

   The documentation shall also include Benchmark scoring results measuring the model's bias, helpfulness, honesty, or accuracy when provided with ambiguous versus straightforward questions. (Including any benchmarks comparing performance across multiple languages, where applicable).

7. **Description of Enterprise-Level Controls**

   The Contractor shall provide documentation describing the Enterprise Governance tools and controls, such as:

   a. Customizable system instructions that are additive to a base model's system prompts or content generation filters.

   b. Product features that require a model to cite sources of its outputs or otherwise provide visibility into the provenance of the model's outputs.

   c. AI System/LLM model evaluation tools that enable comparisons either between a model's outputs, or across various models.

8. **Third Party Modification Disclosure**

   The Contractor shall disclose of any additional controls to modify an AI Model's/LLM's output applied by the Contractor if the Contractor is not a direct developer of the LLM (e.g., classifiers, system prompts, fine-tuning, content moderation and filters, etc.)

Deliverable:

A. AI System/LLM Development and Operation Documentation Package

6.7.2 MONITORING, REPORTING, AND CORRECTIVE ACTION

The Contractor shall develop and implement a Compliance Monitoring and Reporting Plan supporting ongoing monitoring processes to evaluate AI outputs for compliance with Trustworthy AI and Unbiased AI principles. This plan shall include the mechanism for authorized users to provide end user feedback to report suspected violations of Truth-Seeking or Ideological Neutrality requirements.

The Contractor shall notify the COR within 10 business days of identifying any material deviation from these principles and shall submit a written Corrective Action Plan describing mitigation steps, responsible parties, and timelines. Any material deviation, corrective action taken, and results shall be detailed in the monthly Progress Reports.

Deliverable:

A. Compliance Monitoring and Reporting Plan
B. Corrective Action Plan

6.7.3 AI MODEL UPDATES AND CHANGE DISCLOSURES

The Contractor, in an AI Model/LLM Change Disclosure, shall notify the Government throughout the PoP in advance of any material changes to AI models, including new AI enhancements, features and/or components, controls, retraining, classifiers, system prompts, fine-tuning, content moderation, filters, version replacement, or architectural changes, that could reasonably affect compliance with Trustworthy AI or Unbiased AI principles. Updated documentation shall be provided to VA for VA approval prior to implementation of such changes.

Deliverable:

A. AI Model/LLM Change Disclosure

7.0 SECURITY AND PRIVACY REQUIREMENTS

7.1 POSITION/TASK RISK DESIGNATION LEVEL(S)

In accordance with VA Handbook 0710, Personnel Vetting Program, the position sensitivity and the level of background investigation commensurate with the required level of access for the following tasks within the PD are:

Position Sensitivity and Background Investigation Requirements by Service Task/Item Number

Service Task / Item Number	Tier1 / Low Risk	Tier 2 / Moderate Risk	Tier 4 / High Risk
1.2	☒	☐	☐
1.3	☒	☐	☐

The Tasks identified above and the resulting Position Sensitivity and Background Investigation requirements identify, in effect, the Background Investigation requirements for Contractor individuals, based upon the tasks the particular Contractor individual will be working. The submitted Contractor Staff Roster must indicate the required Background Investigation Level for each Contractor individual based upon the tasks the Contractor individual will be working, in accordance with their submitted proposal.

8.0 POINTS OF CONTACT

Program Manager:
Name: Felica Newsome-Dent
Address: 13800 Veterans Way
Orlando, FL 32827
Voice: 407-403-3563
Email: Felica.Newsome-Dent@va.gov

Contracting Officer:
Name: Meghan McCloskey
Address: 23 Christopher Way
Eatontown, NJ 07724
Voice: 848-377-5151
Email: Meghan.Mccloskey@va.gov

Contract Specialist:
Name: Jamie Valentine
Address: 23 Christopher Way
Eatontown, NJ 07724
Voice: 848-377-5091
Email: Jamie.Valentine@va.gov

DRAFT

ADDENDUM B – VA CYBERSECURITY AND PRIVACY LANGUAGE FOR INCLUSION IN ACQUISITIONS

NOTE: In the event of a conflict, VA Acquisition Regulation (VAAR) Security Clauses take precedence over the language in this Addendum B.

FROM: *VA HANDBOOK 6500.6, ACQUISITION CYBERSECURITY, SECTION 8, VA CYBERSECURITY AND PRIVACY LANGUAGE, FOR INCLUSION IN CONTRACTS*

a. GENERAL

1) Contractors, Contractor personnel, Sub-Contractor and Sub-Contractor personnel (hereinafter referred to as "Contractor") will be subject to the same Federal laws, regulations, standards, VA directives and handbooks as VA personnel regarding information and information system security and privacy.

2) VA Cybersecurity and Privacy language included in the solicitation or contract applies to the Contractor and all Contractor affiliates and agents.

3) All information systems, applications, and services operating on behalf of or within VA must meet or exceed all applicable federal cybersecurity and risk management minimum standards. At a minimum, systems shall implement and maintain compliance with the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-37, Risk Management Framework for Information Systems and Organization: A System Life Cycle Approach for Security and Privacy, Federal Information Security Modernization Act of 2014 (FISMA) requirements, and all applicable federal laws, and Office of Management and Budget (OMB) mandates. Contractual terms, implementation approaches, or operational constraints shall not supersede or circumvent these federal minimum security and compliance requirements. Authority established under this handbook is limited to technical, and enterprise architecture matters; interpretation or adjudication of non-technical policy or programmatic content remains the responsibility of the appropriate business or governing policy offices.

b. VA INFORMATION CUSTODIAL

1) The Contractor must provide unlimited rights to data / intellectual property first produced and delivered in the performance of this contract or order (hereinafter "contract") unless expressly stated otherwise in this contract. This includes all rights to source code and all documentation created in support thereof. The primary clause used to define Government and Contractor data rights is Federal Acquisition Regulation (FAR) 52.227-14, Rights in Data – General.

    a) The Contractor must provide all custom-developed code and technical components developed in the performance of this contract (e.g., documentation; data models; schemas; metadata; architecture designs;

configuration scripts; and artifacts required to develop, build, test, and deploy the code for or on behalf of VA) for storage in a VA-designated repository for custom-developed code in a format that allows VA to access, use, modify, distribute, and reuse it in accordance with the Source Code Harmonization and Reuse in Information Technology Act of 2024 (SHARE IT Act).

b) The Contractor must provide any support and assistance deemed necessary for VA to comply with the SHARE IT Act (e.g., furnishing data for reporting and following federal and VA standards for custom code development).

2) Information made available to the Contractor by VA for the performance or administration of this contract will be used only for the purposes specified in the contract, service agreement, SOW, PWS, and / or PD. The Contractor shall not use VA information in any other manner without prior written approval from a VA CO. The Contractor shall disclose to the CO all Data to be collected, stored, and accessed and will only collect, store, and access the minimum Data necessary to perform its services. The Contractor may only use VA information within the terms of the contract and applicable Federal law, regulations, and VA policies. If new Federal laws, regulations, or VA policies become applicable after execution of the contract, the parties agree to negotiate contract modification and adjustment necessary to implement the new laws, regulations, and / or policies. The primary clause used to define Government and Contractor data rights is FAR 52.227-14.

3) The Contractor shall not make copies of VA information unless necessary to perform the requirements of the contract. If copies are made for restoration purposes, after the restoration is complete, the copies shall be destroyed in accordance with VA Directive 6500, VA Cybersecurity Program, and VA Office of Information Security (OIS) Knowledge Service.

4) VA information will not be co-mingled with any other data on the Contractor's information systems or media storage systems. The Contractor shall ensure compliance with Federal and VA requirements related to data protection, data encryption, physical data segregation, logical data segregation, classification requirements and media sanitization. Exceptions to this paragraph will be granted only with the approval of the VA Program Office communicated to the Contractor by the VA CO.

5) Except for uses and disclosures of VA information specifically authorized by this contract, the Contractor may use and disclose VA information only in two situations: (i) in response to a qualifying order of a court of competent jurisdiction after notification to VA CO (ii) with written approval from the VA CO. The

Contractor shall refer all requests for, or inquiries about, VA information and information systems to the VA CO.

6) Notwithstanding the provision above, the Contractor shall not release VA records protected by Title 38 United States Code (U.S.C.) § 5705, Confidentiality of medical quality- assurance records, and / or Title 38 U.S.C. § 7332, Confidentiality of certain medical records pertaining to drug addiction, sickle cell anemia, alcoholism or alcohol abuse or infection with Human Immunodeficiency Virus (HIV). If the Contractor is in receipt of a court order or other form of request for the above-mentioned information, the Contractor shall immediately refer that court order or request to the VA CO.

7) If a VHA contract is terminated for default or cause with a business associate, the related local Business Associate Agreement (BAA) shall also be terminated and actions taken in accordance with Veterans Health Administration (VHA) Directive 1605.05, Business Associate Agreements. If there is an executed national BAA associated with the contract, VA will determine what actions are appropriate and notify the contractor.

8) Information made available to the Contractor by VA for the performance or administration of this contract, or information developed by the Contractor in performance or administration of the contract, will be protected and secured in accordance with VA Directive 6500, VA Directive 6510, VA Identity, Credential, and Access Management, and VA Handbook 6510, VA Identity, Credential and Access Management.

9) The Contractor shall store VA sensitive information in an encrypted form, using VA-approved encryption tools which are Federal Information Processing Standards (FIPS)-validated in accordance with requirements on the OIS Knowledge Service. The Contractor shall verify the integrity of transmitted security and privacy attributes. The Contractor shall provide the capability to check the integrity of VA information while it resides in the external system.

10) The Contractor shall transmit VA sensitive information using VA approved Transport Layer Security (TLS) configured with FIPS based cipher suites in conformance with NIST SP 800-52, Guidelines for the Selection, Configuration and Use of Transport Layer Security (TLS) Implementations. The cryptographic module used must be FIPS-validated in accordance with requirements on the OIS Knowledge Service.

11) The Contractor's firewall security shall meet or exceed VA's minimum requirements.

12) The Contractor shall retain all data storage media which have been used to create, collect, process, store, or disseminate any VA data, information, or

agency record in accordance with National Archives and Records Administration (NARA) requirements as outlined in VA Directive 6300, Records and Information Management, VA Handbook 6300.1, Records Management Procedures, and applicable VA Records Control Schedules.

13) The Contractor shall not store or maintain VA sensitive information, including on any form of removable or transportable media, without CO's prior written approval.

14) The Contractor, in accordance with Federal and VA policy, shall maintain backup of Data containing VA sensitive information, image repositories, and provisioned environments. The backup storage infrastructure shall be located in physically protected, limited-access facilities within the United States and governed by the cybersecurity Controls set forth herein.

15) The Contractor shall provide its plan for the disposition of all VA data in its possession, including destruction and return, in accordance with VA Directive 6500 and requirements specified on the VA OIS Knowledge Service, prior to termination or completion of this contract.

16) The Contractor shall return to VA all data storage media which have been used to create, collect, process, store, or disseminate any VA data, information, or agency record which cannot be sanitized or destroyed as required by Section b(15) of this contract. Such media include, but are not limited to, printed or handwritten hardcopies (containing text or images), magnetic tapes, magnetic discs, optical discs, solid state devices, or any other removable digital or analog data storage media.

17) Media shall be returned using VA-approved methods for secure data transfer. If the media contain VA sensitive information, that information must be encrypted by a VA-approved FIPS-validated encryption tool in accordance with requirements on the OIS Knowledge Service. If the Contractor chooses to ship the media, and the media contain no VA sensitive information, such shipment shall be performed in accordance with VA Directive 6340, Enterprise Mail Management. If any of the media to be shipped contain VA Sensitive Information, the shipment shall be performed in accordance with VA Directive 6609, Mailing of Sensitive Personal Information.

18) The Contractor shall self-certify that the data disposition requirements in Section b (12)-(15) of this contract have been satisfied, and shall send this self-certification to the VA Program Office and the VA CO within 30 business days of the completion or termination of this contract.

19) At the end of any contracted lease, loan, or trade-in of equipment, VA shall not return any electronic storage media included in or with equipment if that media

has been used to create, collect, process, store, or disseminate VA data, information, or agency record. Any exception to this stipulation will be granted only with the written approval of the VA CO.

20) VA reserves the right to conduct scheduled or unscheduled audits, assessments, or investigations of Contractor Information Technology (IT) resources to ensure information security is compliant with Federal and VA requirements in accordance with Title 38 U.S.C. § 5722(b)(1). This includes, but is not limited to, periodic assessments of the risk and magnitude of harm that could result from the unauthorized access, use, disclosure, disruption, modification, or destruction of information and information systems that support the operations and assets of VA. The Contractor shall provide all necessary access to records (including electronic and documentary materials related to the contracts and subcontracts) and support (including access to Contractors associated with the contract) to VA, VA's Office Inspector General (OIG), and / or the Government Accountability Office (GAO) staff during periodic control assessments, audits, or investigations.

c. ACCESS TO VA INFORMATION AND VA INFORMATION SYSTEMS

1) All Contractors shall comply with conditions specified in the Veterans Affairs Acquisition Regulation (VAAR) 852.204-71(d), and Contractor operations are required to be in U.S. All Contractors working with VA information must be permanently located within a jurisdiction subject to the law of the U.S. to the maximum extent practicable. The Contractor shall also ensure to restrict the geographic location of information processing and data storage to facilities located within the legal jurisdictional boundary of the U.S. If services are proposed to be performed abroad, the Contractor must state where all non-U.S. services are provided and obtain the CO's prior written approval where required by law.

2) The Contractor shall deliver to VA a detailed risk mitigation plan specifically addressing communications, personnel control, data protection and potential legal issues. The plan shall be approved by the Contracting Officer (CO) in writing prior to access being granted.

3) The Contractor shall ensure that all Contractors assigned to work on the contract undergo the same security investigations and obtain the same levels of clearance as VA employees who have been granted access to VA information at the same level of sensitivity. The level and process of background security investigations for Contractors shall be in accordance with VA Directive 0710, Personnel Vetting Program, and VA Handbook 0710, Personnel Vetting Program.

4) The Contractor shall request logical (electronic) or physical access to VA information and VA information systems only to the extent that the requested

information is needed to perform the services specified in the solicitation or contract. Contractors who require privileged access to any VA Information System (or component) shall complete the VA elevated privilege access request processes before privileged access is granted.

5) Before being granted access to VA information or VA information systems, Contractors shall:

    a) Successfully complete VA Privacy and Information Security Awareness and Rules of Behavior (RoB) course [Talent Management System (TMS) #10176] upon contract initiation and annually thereafter;

    b) Sign and acknowledge (electronically through TMS #10176) understanding of and responsibilities for compliance with the VA RoB for Organizational Users; and

    c) Successfully complete all additional cybersecurity or privacy training required for personnel granted equivalent information system or information access.

6) The Contractor shall provide to the VA Program Office a copy of each applicable employee's training certificates and certificate of signature of the VA RoB for Organizational Users within five (5) business days of contract initiation and annually thereafter. Failure by the Contractor to complete the mandatory annual training is grounds for suspension or termination of all privileges to access VA information physically or electronically and removal from work on the contract until such time as the required training has been successfully completed.

    a) The Contractor shall notify the VA Program Office and the VA CO in writing immediately (within 24 hours) after any of the following events:

        i. The Contractor no longer needs access to VA information or VA information systems.

        ii. The Contractor is terminated, suspended, or otherwise has their work on a VA project discontinued for any reason.

        iii. The Contractor believes that a member of their own personnel may pose a threat to the Contractor's working environment or to any Contractor-owned assets (e.g., property, buildings, confidential data, COs, employees, networks, systems, trade secrets and / or VA data entrusted to the Contractor).

DRAFT

iv. Discovery or revelation of previously undisclosed changes to a Contractor's background history, background investigation, or employee record.

v. The Contractor has their authorization to work in the U.S. revoked.

vi. The contract by which Contractors provides products and services to VA has either been fulfilled or terminated, such that VA can cut off electronic and / or physical access for the Contractor.

7) The Contractor is not permitted to access the VA network or internal resources from any foreign country. When travel outside the United States is required for official VA business or an international work location is explicitly specified in the contract, the Contractor must submit a request for accessing the VA internal network and resources internationally subject to the written approval by the Contracting Officer's Representative (COR) and all required VA approvers. If approved, the Contractor must adhere to all approval conditions for accessing VA networks or internal resources via VA-issued Government Furnished Equipment (GFE), contractor supplied devices, personal devices with appropriate remote desktop features, or personal devices enrolled in VA's Bring Your Own Device (BYOD) program.

8) The Contractor is not permitted to travel outside the U.S. with any VA-issued GFE. If international travel is required for official VA business or an international work location is explicitly specified in the contract, an exception may be requested and is subject to written approval by the COR and all required VA approvers.

9) In such cases of contract fulfillment, termination, or other causes, the Contractor shall take the necessary measures to immediately revoke access to VA network, property, information, and information systems (logical and physical) by the Contractor. These measures include (but are not limited to): removing and then securing Personal Identification Verification (PIV) badges and PIV–Interoperable (PIV-I) access badges, VA-issued photo badges, credentials for VA facilities and devices, VA-issued laptops, and authentication tokens. Contractors shall notify the VA Program Office immediately to initiate access removal.

10) Contractors who no longer require VA access will return VA-issued assets to VA (e.g., documents, electronic equipment, keys, and parking passes). PIV and PIV-I access badges shall be returned to the nearest VA PIV Badge Issuance Office. Once they have had access to VA information, information systems, networks and VA property in their possessions removed, Contractors shall notify the VA Program Office.

d. SECURITY INCIDENT INVESTIGATION

1) The Contractor shall immediately (within one hour) report suspected security / privacy incidents (including intrusions) to the CO and VA Office of Information and Technology's (OIT) Enterprise Service Desk (ESD) by calling (855) 673-4357 [Text Telephones (TTY)-based Telecommunications Relay Service: 711].

2) The Contractor's immediate notice to VA about the incident shall include the following information about the incident, to the extent that this information is known:

    a) Date and time (known or approximated) the security incident occurred.

    b) Names of individuals involved (when applicable).

    c) Location (physical and / or logical, as applicable) of the incident.

    d) Event logs related to the incident in a format agreed upon by the Contractor and VA.

    e) Actual or potential security issues associated with any Contractor-designed Product Known Exploited Vulnerabilities (KEVs). i The Contractor shall create, implement, and maintain a process to record, track, and report all KEVs.

    f) Amount (in number of files or records) of data belonging to VA believed to have been compromised; and

    g) Immediate remediation and mitigation measures the Contractor is taking to minimize exposure to the vulnerability and impact of future incidents of a similar nature including timeframes.

3) After providing the initial incident summary to VA, the Contractor shall continue to provide written updates on any new relevant information about the incident and provide updates at the request of VA officials. The Contractor shall fully cooperate with VA or third-party entity performing an independent risk analysis. Failure to cooperate may be deemed a material breach and grounds for contract termination.

4) If the incident involves theft or break-in or other criminal activity, the Contractor must concurrently report the incident to the appropriate law enforcement entity (or entities) of jurisdiction, including to the VA OIG and to the VA Office of Security and Law Enforcement. The Contractor shall cooperate with VA and any law enforcement authority responsible for the investigation and prosecution of any possible criminal law violation(s) associated with any incident. The Contractor shall cooperate with VA in any civil litigation to recover VA

information, obtain monetary or other compensation from a third party for damages arising from any incident, or obtain injunctive relief against any third party arising from, or related to, the incident.

5) The Contractor shall comply with VA Handbook 6500.2, Management of Breaches Involving Sensitive Personal Information, which establishes the breach management policies and assigns responsibilities for the oversight, management and reporting procedures associated with managing of breaches.

6) The Contractor shall follow VA Directive 6500 and VA OIS Knowledge Service guidance for implementing an Incident Response Plan or integrating with an existing VA implementation.

7) With respect to unsecured Protected Health Information (PHI), the Contractor is deemed to have discovered a data breach when the Contractor knew or should have known of breach of such information. When a business associate is subject to the requirements of a VHA-issued contract, notification to the covered entity (VHA) shall be made in accordance with the executed BAA.

8) If the Contractor or any of its agents fails to protect VA Sensitive Personal Information (SPI) or otherwise engages in conduct which results in a data breach involving any VA SPI, the Contractor processes or maintains under the contract; the Contractor shall pay liquidated damages to VA as set forth in VAAR clause 852.211-76, Liquidated Damages—Reimbursement for Data Breach Costs.

e. INFORMATION SYSTEM DESIGN AND DEVELOPMENT

1) The Contractor shall design and develop information systems in compliance with all VA Directives and Handbooks. This includes standards for the protection of electronic PHI, outlined in 45 Code of Federal Regulations (CFR)Part 164, Subpart C and information and system security categorization level designations in accordance with FIPS 199, Standards for Security Categorization of Federal Information and Information Systems and FIPS 200, Minimum Security Requirements for Federal Information Systems. Baseline security controls shall be implemented commensurate with the FIPS 199 system security categorization [reference VA Handbook 6500, Risk Management Framework for VA Information Systems - VA Information Security Program, and VA Trusted Internet Connections (TIC) Architecture].

2) Contracted new developments require creation, testing, evaluation, and authorization in compliance with VA Assessment and Authorization (A&A) processes in VA Handbook 6500 and VA OIS Knowledge Service to obtain an Authorization to Operate (ATO). Full compliance with defined VA Critical Security Controls shall be mandatory.

3) The Contractor shall comply with the OMB Memorandum M-24-15, Modernizing the Federal Risk and Authorization Management Program (FedRAMP), when using any cloud computing products. The information system is classified as a cloud system if it meets the criteria as outlined in NIST SP 800-145, The NIST Definition of Cloud Computing. For any cloud systems, the Contractor shall leverage the FedRAMP authorization process to achieve an authorization to operate in a VA environment. This consists of either leveraging an existing FedRAMP authorization for the information system or achieving FedRAMP authorization, if the system does not have an existing FedRAMP authorization at the appropriate FIPS 199 impact level.

4) VA IT Contractors shall address and / or integrate applicable VA Handbook 6500 and OIS Knowledge Service specifications in delivered IT systems / solutions, products and / or services. Contractors shall comply with FAR 39.1, General, specifically the prohibitions referenced. If information system solutions, products and / or services do not directly match VA security requirements, the Contractor shall work with the VA Program Office for governance or resolution and inform VA CO of any unresolved compliance issues.

5) The Contractor shall ensure that all delivered applications and information systems enforce multi-factor authentication (MFA) for privileged accounts and non-privileged accounts in compliance with Homeland Security Presidential Directive (HSPD) 12 and VA Identity, Credential and Access Management (ICAM) enterprise identity management requirements as set forth in OMB Memo M-19-17, Enabling Mission Delivery through Improved Identity, Credential, and Access Management; OMB M-05-24, Implementation of HSPD 12 – Policy for a Common Identification Standard for Federal Employees and Contractors; FIPS 201-3, Personal Identity Verification (PIV) of Federal Employees and Contractors (or its successor); and supporting NIST guidance. This applies to Commercial Off-The-Shelf (COTS) product(s) that the Contractor did not develop, all software configurations and all customizations.

6) The Contractor shall ensure all Contractor-delivered applications and information systems explicitly authenticate, authorize, and disable all subjects, assets, and workflows across systems.

7) All Contractor Product cybersecurity features shall either be enabled by default or be clearly identified as requiring initial configuration. Product documentation shall specify how to enable, configure, and use all Product cybersecurity features.

8) The Contractor shall eliminate default or hardcoded passwords from the organization's software products.

9) The Contractor shall provide user authentication services compliant with VA Directive 6500, VA Handbook 6500, VA Directive 6510, VA Handbook 6510, and

NIST SP 800-63, Digital Identity Guidelines, for direct, assertion-based authentication and / or trust-based authentication, as determined by the application's / system's design and integration patterns. Direct authentication at a minimum must include Public Key Infrastructure (PKI) based authentication supportive of PIV and / or Common Access Card (CAC), as determined by the business need and compliance with VA OIS Knowledge Service specifications.

10) Prior to acceptance or connection into an authorized VA computing environment, the Contractor shall use VA-authorized technical security baseline configurations and shall certify that applications are fully functional and operate correctly as intended on information systems in compliance with VA baselines. If the Defense Information Systems Agency (DISA) has created a Security Technical Implementation Guide (STIG) for the technology, the Contractor may use that STIG to specify the configuration settings. If VA determines that a new or updated VA configuration baseline needs to be created, the Contractor shall provide required technical support to specify the configuration settings for that baseline.

11) The standard installation, operation, maintenance, updating and patching of software shall not alter the configuration settings from VA-approved baseline configuration. Software developed for VA must be compatible with VA enterprise installer services and install to the default "program files" directory using a silent install / uninstall mechanism. The Contractor shall perform testing of all updates and patching prior to implementation on VA systems.

12) Applications designed for normal end users will run in the standard user context without elevated system administration privileges.

13) The Contractor-delivered solutions shall reside on VA-approved operating systems.

14) The Contractor shall design, develop, and implement security and privacy controls, including any applicable physical security controls, in accordance with the provisions of the VA security system development life cycle outlined in NIST SP 800-37, VA Directive 6500, and VA Handbook 6500.

15) The Contractor shall comply with the Privacy Act of 1974 (the Privacy Act), FAR 52.224-2, Privacy Act, and VA rules and regulations issued under the Privacy Act in the design, development, or operation of any system of records (SOR) on individuals to accomplish a VA function.

16) Any use of Personally Identifiable Information (PII) and live data during the design, development, and testing of systems and system components must be approved by VA.

17) The Contractor shall ensure the security of all procured or developed information systems, major applications, minor applications, devices, enclaves and platform information technologies, including all their hardware, firmware, and software subcomponents (hereinafter referred to as “information systems”) throughout the life of this contract and any extension, warranty, or maintenance periods. This includes applying security configurations, workarounds, patches, hotfixes, upgrades, replacements and adding or upgrading any physical components as necessary to remediate all security vulnerabilities published or known to the Contractor anywhere in the information systems. The Contractor shall ensure that security fixes do not negatively impact the information systems being designed and / or developed by the Contractor. Additionally, the Contractor shall take proactive measures to address entire classes of vulnerabilities such as implementing secure software design practices, using the Cybersecurity and Infrastructure Security Agency (CISA) KEV Catalog to prioritize patching efforts for internet facing resources, and adopting a Zero Trust model to ensure continuous authentication and authorization of users and devices, both inside and outside the network.

18) When the Contractor is responsible for operations or maintenance of the information systems, the Contractor shall apply the security fixes within the timeframe specified by the associated controls on the VA OIS Security Knowledge Service. When security fixes involve installing third-party patches (such as patches issued by Microsoft or Adobe), the Contractor shall provide written notice to the VA Program Office that the patch has been validated to not negatively impact the information system(s) to which it was applied.

f. INFORMATION SYSTEM HOSTING, OPERATION, MAINTENANCE OR USE

1) The Contractor shall comply with all Federal laws, regulations, and VA policies for cloud-based and non-cloud-based information systems hosted, operated, maintained, or used on behalf of VA. VA OIS Knowledge Service Security controls for collecting, processing, transmitting, and storing of VA sensitive information, must be in place. Prior to hosting, operation, maintenance or use of the information system by or on behalf of VA, the security controls will be tested by VA or a VA-approved sanctioned third party assessment organization (3PAO) then approved by VA. This testing includes conducting compliance risk assessments, security architecture analyses, vulnerability scanning, system patching, change management procedures and the completion of acceptable contingency and incident response plans for each information system. The Contractor’s security control procedures shall be the equal to or greater than procedures used by VA to operate and maintain information systems.

2) When the Contractor operates, as an IT managed service, a VA information system, data network, telecommunications system or network, each of the Contractor system(s) to be used in delivery of the managed services to VA will be

part of the VA A&A processes in accordance with VA Handbook 6500 and specifications in the VA OIS Knowledge Service (in accordance with OMB M-24-15). Full compliance with defined VA Critical Security Controls shall be mandatory. After completion of its VA A&A, any major change to that A&A package will require a review of all the package documentation and artifacts for potential impact of the change and may require an update to reflect that change.

3) Contractor systems, services, and devices must maintain an event logging capability compliant with OMB Memorandum M-26-14, Ensuring Effective and Efficient Agency Logging and Network Visibility to Defend Against Cyber Threats, and VA requirements. The Contractor must provide any support and assistance (including data) deemed necessary for VA to comply with OMB M-26-14.

4) The Contractor shall identify the Operating System (OS) and all software in its Devices. Devices must not be running any OS software within two (2) years of End of Support by an OS third-party supplier at the time of Contractor's committed delivery to the service location and / or expected use. If any device is running an OS within two (2) years of obsolescence, the Contractor shall upgrade the Device to a non-obsolete OS, at the Contractor's expense.

    a) The Contractor may offer an extended support agreement to defer OS replacement under conditions mutually agreed upon by the Contractor and the CO.

    b) For all Devices currently at any Service Location, the Contractor shall verify whether the installed OS is within one (1) year of obsolescence and shall notify the CO of an upgrade option for such Devices to a supported OS i Where this requirement is not currently feasible, the Contractor shall provide documentation of their roadmap to achieve these requirements within two (2) years.

5) The Contractor shall return to VA all data storage media (hard drives, optical disks, CDs, back-up tapes, etc.) used with non-VA leased or non-VA owned IT equipment when that equipment has been used to create, collect, process, store, transmit, disseminate, or dispose VA information in accordance with A&A package requirements. This applies when the contract is terminated or completed and prior to disposal of media. The Contractor shall provide its plan for destruction of all VA data in its possession in accordance with VA Directive 6500 and requirements specified on the VA OIS Knowledge Service, prior to termination or completion of this contract. Within thirty (30) business days of contract termination, the Contractor shall send to the VA Program Office and the VA CO a self-certification that the data disposition requirements above have been satisfied.

6) All external Internet connections to VA network which will be used to transmit or receive VA information must be implemented in accordance with the VA TIC Reference Architecture, VA Directive 6513, Secure External Connections; Handbook 6513, Secure External Connections; and the Memorandum of Understanding (MOU) and Interconnection Security Agreement (ISA) processes specified in the VA OIS Knowledge Service. The security terms and conditions under which that connection will be permitted to operate and carry VA data shall be reviewed and approved by VA prior to implementation.

7) Contractor procedures associated with information system security and privacy shall be subject to periodic, announced, or unannounced assessments by VA officials. The physical security aspects associated with Contractor activities are also subject to such assessments. The Contractor shall report, in writing, any deficiencies noted during the above assessment to the VA COR / CO. The Contractor shall use VA's defined processes to document planned remedial actions that address identified deficiencies in the Contractor's information security policies, procedures, and practices. The Contractor shall correct security deficiencies within the timeframes specified in the VA OIS Knowledge Service.

8) All major information system changes which occur in the production environment shall be reviewed by VA to determine the impact on privacy and security of the system. Based on the review results, updates to the ATO documentation and parameters may be required to remain in compliance with VA Handbook 6500 and VA OIS Knowledge Service requirements.

9) The Contractor shall conduct a privacy and security self-assessment on all information systems and outsourced services as required by the contract. A report containing the self-assessment results shall be provided to the VA Program Office. The Contractor shall correct or mitigate any weaknesses discovered during the assessment. VA reserves the right to conduct assessment at its discretion, using Government personnel or a third party if deemed necessary.

10) The Contractor shall not install or use personally owned or Contractor-owned equipment or software on any VA network or information systems. If non-VA owned equipment must be used to fulfill the requirements of a contract, it must be documented in the contract. All VA-approved Contractor Other Equipment (OE) will be subject to technical inspection by VA at any time. On all VA-approved OE, the Contractor shall:

    a) Implement the same VA OIS Knowledge Service Security Controls required for equivalent GFE.

    b) Fund any configuration changes required to the OE.

c) Provide, install, operate, and maintain antivirus software and a personal host-based or enclave-based firewall configured with a VA-approved configuration for all OE with a network connection; and

d) Apply all critical updates and patches to the software and firmware of the OE.

11) Upon discovery of an incident, the Contractor shall conduct an impact analysis jointly with VA, and, if deemed necessary, isolate all affected components from the connected network(s).

12) The Contractor shall develop policies and procedures for disclosing to VA any discovery by the Contractor of a material defect or vulnerability in a product or service the Contractor provides to VA and shall implement said policies and procedures upon contract initiation. These policies and procedures shall require the Contractor to provide a summary document, within thirty (30) business days of discovery, about every material defect(s) or vulnerability(ies) discovered. This document shall include a root cause analysis and description of the potential impact of each defect / vulnerability, a list of compensating security controls and other mitigations to be undertaken, a list of recommended corrective actions and / or workarounds (e.g., monitoring).

13) When any backdoor (i.e., a method for bypassing user authentication) is known or discovered by the Contractor in a product / service provided by the Contractor to VA, the Contractor shall permanently remediate the backdoor and provide to the VA Program Office and the VA CO a written attestation that the backdoor has been permanently remediated. The Contractor shall remediate all other vulnerabilities based on risk, including those discovered through routine scanning and other assessments, in accordance with the remediation timelines specified by the VA enterprise vulnerability management program, the OIS Knowledge Service and the applicable timeframe mandated by CISA Binding Operational Directive (BOD) 26-04, Prioritizing Security Updates Based on Risk. Exceptions to this paragraph will be granted only with the approval of the VA Program Office communicated to the Contractor by the VA CO.

g. SECURITY AND PRIVACY CONTROLS COMPLIANCE TESTING, ASSESSMENT, AND AUDITING

1) Upon request from VA, the Contractor shall provide copies of the policies, procedures evidence, and summaries of independent reports issued to or by the Contractor's organization (i.e., corporation, sole proprietorship, partnership, limited liability company (LLC), or other legal business structure) pertaining to the Contractor's compliance with specified security frameworks such as International Organization for Standardization (ISO) frameworks, the NIST Risk Management Framework (RMF), NIST Cybersecurity White Paper (CSWP) 29, NIST

Cybersecurity Framework (CSF) 2.0, NIST Privacy Framework, and HITRUST CSF.

2) The Contractor shall permit VA or a VA-designated third party to perform security audits and tests, including penetration tests, of the Contractor's IT, systems, and security and privacy controls to ascertain whether the Contractor is compliant with the information security, network, and system requirements mandated in the contract.

3) Any audits or tests VA elects to carry out will commence within thirty (30) business days of VA notification to the Contractor. Such audits, tests and assessments may include the following:

   a) security / penetration tests which both sides agree will not negatively impact Contractor operations;

   b) interviews with VA-indicated stakeholders and cybersecurity practitioners;

   c) document reviews; and

   d) technical inspections of networks or systems the Contractor uses to create, collect, process, store, transmit, disseminate, protect, retain, or dispose of VA data, information, or agency record on behalf of VA. Prior to these audits, tests and assessments, the Contractor shall provide all information requested by VA (e.g., equipment lists, network / infrastructure diagrams, policy documents, system logs, audit logs, other records providing details related to the Contractor's information systems used on behalf of VA).

4) The Contractor shall comply with all recommendations resulting from VA audits, inspections, and tests. The Contractor will notify VA about the existence of any reports the Contractor generates during its own security and privacy assessments and tests, and shall upon request by VA provide copies of those reports to VA. The Contractor shall grant access to its security assessment / test reports and other documentation requested by VA to VA-designated auditors and other Government partners on a need-to-know basis; such access will be coordinated through the VA Program Office. The Contractor shall comply with all recommendations provided by VA regulators and Government partners after completion of their regulatory assessments.

h. PRODUCT INTEGRITY, AUTHENTICITY, PROVENANCE, ANTI-COUNTERFEIT AND ANTI-TAMPERING

1) The Contractor shall comply with CFR Title 15 Part 791, Securing the Information and Communications Technology and Services (ICTS) Supply Chain, including

any applicable prohibition, mitigation measure, or other requirement concerning ICTS transactions involving a foreign adversary. ICTS Transactions are defined as any acquisition, importation, transfer, installation, dealing in or use of any information and communications technology or service, including ongoing activities, such as managed services, data transmission, software updates, repairs or the platforming or data hosting of applications for consumer download.

2) In accordance with Section 889(a)(1)(A) of the John S. McCain National Defense Authorization Act (NDAA) for Fiscal Year 2019, the FAR, the VAAR, and all other relevant laws and regulations, the Contractor is prohibited from providing to VA any equipment, system, or service that uses telecommunications or IT equipment or services produced or provided by entities that the VA is prohibited from conducting business with. Conducting business includes, but is not limited to, procuring or obtaining, or extending or renewing a contract to procure or obtain, any equipment, system, or service.

3) The Contractor shall purchase or acquire equipment from an Original Equipment Manufacturer (OEM) or an authorized reseller of an OEM. The Contractor shall attest that all equipment procured to satisfy requirements of the contract is authentic. If the required equipment is not available from an OEM or an authorized reseller, the Contractor shall submit with their proposal details of circumstances preventing procurement of the equipment from an OEM or authorized reseller.

4) The Contractor shall establish, implement, and provide documentation of the Contractor's supply chain risk management practices governing the delivery of hardware, firmware, and software (including software updates and patches) specified under this agreement. Such documentation will include chain-of-custody practices, integrity management program for Contractor-provided components or parts, and replacement parts requests. The Contractor shall make spare parts available. The Contractor shall specify how digital delivery of procured software or data products (including updates and patches) will be validated and monitored to ensure consistent and secure delivery. The Contractor shall apply encryption technology to protect and validate the authenticity and integrity of procured products throughout their delivery processes.

5) If a Contractor provides software or patches to VA, the Contractor shall also publish or provide a digital hash for validating the authenticity and integrity of the software. This hash must a FIPS-validated hash function in accordance with the requirements on the OIS Knowledge Service.

6) The Contractor shall provide a Software Bill of Materials (SBOM) for each software product provided to VA by the Contractor. The SBOM will consist of a list of software components, associated metadata, and documentation which

collectively comprise the software product. The SBOM must be generated in one of the data formats defined in the National Telecommunications and Information Administration (NTIA) report, The Minimum Elements for a Software Bill of Materials (SBOM), or comply with other relevant federal guidance regarding format.

7) VA may require the Contractor to attest to conformity with secure software development practices when risk analysis indicates (e.g. providing self-attestation through the Secure Software Development Attestation Form).

8) The Contractor shall use or arrange for the use of VA approved trusted channels to ship procured products, such as U.S. registered mail and / or tamper-evident packaging for physical deliveries.'
9) Throughout the delivery process, the Contractor shall demonstrate a capability for detecting and preventing unauthorized access (tampering).

10) The Contractor shall obtain and maintain chain-of-custody documentation for procured products. The Contractor shall require all IT hardware products to be delivered in tamper-evident packaging.

i. VIRUSES, FIRMWARE AND MALWARE

1) The Contractor shall exercise due diligence to ensure that all provided software and patches, including third-party patches, are free of viruses and / or malware before releasing them to or installing them on VA information systems. If the Contractor or any of its agents fails to protect VA SPI or otherwise engages in conduct which results in a data breach involving any VA SPI the Contractor processes or maintains under the contract, the Contractor shall pay liquidated damages to VA as set forth in VAAR 852.211-76, Liquidated Damages—Reimbursement for Data Breach Costs.

2) The Contractor warrants it has no knowledge of and did not insert, any malicious virus and / or malware code into any software or patches provided to VA which could potentially harm or disrupt VA information systems. If a virus or other malware is introduced, the Contractor shall:

    a) Take all necessary actions to correct the incident, to include all assistance to VA to eliminate the virus or other malware throughout VA's information networks, computer systems and information systems; and

    b) Use commercially reasonable efforts to restore operational efficiency and remediate damages due to data loss or data integrity damage, if the virus or other malware causes a loss of operational efficiency, data loss, or damage to data integrity.

3) The Contractor shall provide or arrange for the provision of technical justification as to why any “false positive” hit has taken place to ensure their code’s supply chain has not been compromised. Justification may be required, but is not limited to, when install files, scripts, firmware, or other Contractor-delivered software solutions (including third-party install files, scripts, firmware, or other software) are flagged as malicious, infected, or suspicious by an anti-virus service / solution.

j. CRYPTOGRAPHIC REQUIREMENT

1) For each product and service provided to VA by the Contractor, the Contractor shall document how each cryptographic system implemented or relied on by that product or service protects (1) the confidentiality and integrity of data and data flows processed by the product / service, (2) the integrity of the product's / service's software code and code execution environments, (3) the authentication of the product's / service's users, devices, and software agents, and (4) the non-reputability of actions performed by the product or service.

2) The cryptographic functions implemented by or relied on by the Contractor's products and services shall implement a FIPS-validated cryptographic methods in accordance with requirements on the OIS Knowledge Service. and, if the product / service implements or relies on TLS, NIST SP 800-52.

3) The Contractor shall provide or arrange for the provision of an automated remote key-establishment method which protects the confidentiality and integrity of the cryptographic keys used by the cryptographic mechanisms implemented or relied on by the Contractor’s products, services, and external systems.

4) The Contractor shall ensure that emergency re-keying of all cryptographic mechanisms implemented or relied on by the Contractor’s products and services can be remotely performed within thirty (30) business days.

5) The Contractor shall provide or arrange for the provision of a method for updating the cryptographic primitives or algorithms implemented or relied on by the Contractor’ products and services.

k. PATCHING GOVERNANCE

1) Prior to the connection of electronic devices, assets or equipment to VA’s assets, the Contractor shall provide documentation detailing the Contractor’s process for software and firmware patch management updates (to include third-party software) and software and firmware vulnerability management updates (to include third-party software). This detailed documentation will:

a) Identify the methods (including the role(s) responsible), mechanisms, and tools to be used by the Contractor to perform the patching process.

b) Identify the methods, mechanisms, and tools to be used or provided for VA to use (e.g., how the integrity of a patch or update is validated by VA); and

c) Describe the approach and capabilities that will be used to remediate newly reported zero-day vulnerabilities in Contractor products and services.

2) Prior to delivery of procured products to VA, the Contractor shall provide documented verification that all of those procured products (including third-party applications, hardware, software, operating systems, and firmware) have had the appropriate updates and patches installed.

3) Prior to the delivery of product, the Contractor shall publish and provide accurate Common Vulnerabilities and Exposures (CVE) records which include Common Weakness Enumeration (CWE) and Common Platform Enumeration (CPE) fields for their organization's products. This includes accurate CWE and CPE fields in every CVE record for the organization's products. Additionally, issue CVEs in a timely manner for, at minimum, all critical or high impact vulnerabilities (whether discovered internally or by a third party) that either require actions by the contractor to patch or have evidence of active exploitation.

4) The Contractor shall provide or arrange for the provision of appropriate hardware, software and firmware updates to remediate newly discovered vulnerabilities or weaknesses in the Contractor’s products and services. This includes any third-party products integrated into the Contractor’s product, service, or system environment. Updates to remediate critical or emergent vulnerabilities, such as Zero-day vulnerabilities, CISA Emergency Directives, and CISA escalated vulnerabilities, must be tested and applied as soon as possible, and no later than within fourteen (14) business days of vulnerability discovery. Updates to remediate non-critical vulnerabilities must be applied within thirty (30) business days of the vulnerability discovery. If updates cannot be made available by the Contractor within these specified time periods, the Contractor shall submit mitigations, methods of exploit detection and / or workarounds to the VA Program Office and the VA CO prior to the aforementioned deadlines.

I. SPECIALIZED DEVICES / SYSTEMS (MEDICAL DEVICES, SPECIAL PURPOSE SYSTEMS, RESEARCH SCIENTIFIC COMPUTING DEVICES)

1) Contractor-supplied / Contractor-delivered Medical Devices, Special Purpose Systems (SPS), Research Scientific Computing Devices (RSCD), Internet of Things (IoT) devices, or other Operational Technology (OT) elements shall

comply with all applicable Federal laws, regulations, and policies, including all applicable VA policies. The specification, design, development, testing, evaluation, and authorization of new Medical Devices, SPS, RSCDs, IoT devices, or OT elements must comply with the requirements specified by VA Handbook 6500. The Contractor shall identify and document any deviations from Federal laws, regulations, and exemptions from VA requirements outlined in this Handbook through the VA's Enterprise Risk Analysis (ERA) for Medical and Specialized Devices / Systems process. All such devices must undergo the ERA process prior to implementation and initiation of the ATO process.

2) The Contractor shall address and / or integrate applicable VA Directive 6500, VA Handbook 6500, and OIS Knowledge Service specifications in delivered IT systems / solutions products and / or services. If systems / solutions products and / or services do not directly match VA security requirements, the Contractor shall work though the VA Program Office to define and implement risk remediation or mitigation.

3) The Contractor shall certify to the VA Program Office that Contractor provided devices / systems which have completed the VA ERA process for Specialized Devices / Systems are fully functional and operate correctly as intended. Whenever VA determines a new VA ERA needs to be created or that a previously approved ERA requires an update (e.g., after that device has undergone a major change), the Contractor shall provide the technical support necessary to specify the configuration settings.

4) The Contractor shall ensure all Contractor-provided medical devices comply with practices documented by the FDA in Cybersecurity in Medical Devices: Quality Management System Considerations and the Content of Premarket Submissions and Postmarket Management of Cybersecurity in Medical Devices.

5) The Contractor shall ensure all Contractor-provided IoT devices comply with the Federal Communications Commission's U.S. Cyber Trust Mark Program requirements by January 4, 2027.

6) The Contractor shall ensure all Contractor-provided IoT devices comply with NIST IoT guidance and standards such as NIST SP 800-213, IoT Device Cybersecurity Guidance for the Federal Government: Establishing IoT Device Cybersecurity Requirements. In accordance with the IoT Cybersecurity Improvement Act of 2020 and FISMA reporting guidance memo for the current fiscal year, VA will not procure or obtain any IoT device that it determines would prevent compliance with the NIST IoT standards and applicable VA policies. This prohibition may be waived only if the VA Chief Information Officer (CIO), or the CIO's designee, determines that at least one of the following conditions is met:

    a) The waiver is necessary in the interest of national security.

b) Procuring, obtaining, or using the IoT device is necessary for research purposes; or

c) The device is secured using alternative and effective methods appropriate to its function.

7) The Contractor shall design its devices / systems to be capable of accepting all applicable security patches. The application of patches may be accomplished either with Contractor personnel support or without (e.g., through automation). If patching can only be completed by Contractor personnel, the Contractor shall commit the resources needed to patch all applicable devices / systems at all VA locations. If unique patching instructions or packaging are needed, the Contractor shall provide the necessary information in conjunction with the validation / testing of the patch. The Contractor shall apply security patches within thirty (30) business days of the patch release and shall have a formal tracking process for any security patches not implemented. For each patch that cannot be applied to a particular device / system, the Contractor shall provide a documented explanation of why the device / system cannot be patched.

8) The Contractor shall implement Secure by Design security techniques in the development, design, and architecture of Devices to:

a) Protect the confidentiality, integrity, and availability of Device Data throughout its lifecycle during the distribution, deployment, and maintenance of Devices; and

b) Maintain the critical functionality of Devices throughout any Cybersecurity Event.

9) The Contractor shall document and deliver to the CO that:

a) All Product communications capabilities (e.g., protocols, ports, services, dataflows) are fully documented and disclosed.

b) All network services including protocols, ports, and services not required for Product's use shall be disabled and / or blocked prior to or during installation. Alternatively, Contractors shall document instructions to disable and / or block network services; and

c) Recommends additional mitigating controls when the Product's features cannot be disabled and / or blocked.

10) The Contractor shall disclose to the CO all accounts on Contractor-supplied Products. All accounts not required for proper operation, use, maintenance, or

administration of the Contractor-supplied Product shall be removed before delivery or during installation.

11) The Contractor shall ensure that all Contractor-supplied / Contractor-delivered devices / systems provided to VA are capable of one of the following:

a) Having a VA-approved antivirus / anti-malware solution installed and maintained capable of executing the antivirus / anti-malware solution's processes for file quarantining and installation of updates (whether proactive or in response to incidents); or

b) Having a whitelisting application installed that specifies which software is permitted to be installed on the device / system which prevents installation of all other non-whitelisted software. Option (b) is permissible only for devices / systems not capable of Option (a).

12) The Contractor shall collect, retain, and provide to the CO logs including time / date stamps of operational events from systems, services, applications, network devices, security devices, authentication controls, and anti-virus / anti-malware for Contractor-managed Security Controls related to systems, services, applications, and data that are owned, rented, leased, or shared by VA in accordance with the Health Insurance Portability and Accountability Act of 1996 (HIPAA), NARA requirements, VA Directive 6300, VA Handbook 6300.1, and applicable VA Records Control Schedules.

13) The Contractor shall represent and warrant that device/system can log operational functions and ensure that the CO can review all logged data any time after data is logged for the device/system in accordance with HIPAA, NARA requirements, VA Directive 6300, VA Handbook 6300.1, and applicable VA Records Control Schedules.

14) Prior to a device / system delivery to or installation in a VA facility, the Contractor shall provide documented verification that all software embedded within that device / system is free from known viruses and malware.

15) The Contractor shall harden any operating system provided in any Contractor-designed Product including, but not limited to:

a) Removal of all software and installation media not specifically required for such Products.

b) Removal or disablement of all scripts, messaging services, data, and third-party installation tools after installation.

c) Disablement to the extent feasible of all physical hardware ports and drives not required for use or operation of such Products after installation; and

d) Documenting of all hardening installation media, tools, and processes used, and all Product features, ports, drives, software, and code that remained and was removed, disabled, and not disabled.

16) Devices and other equipment or systems containing media (e.g., hard drives, optical disks, solid state drives, and storage via chips / firmware) with VA sensitive information will be returned to the Contractor with media removed. When the contract requires return of equipment, the options available to the Contractor are the following:

a) The Contractor shall accept the system without the drive, firmware and solid state.

b) VA's initial device purchase will include a spare or replacement medium which must be installed in place of the original medium prior to return of the device / system.

c) When the highly specialized or proprietary nature of the device / system hardware, firmware, or software makes removal and replacement of the data storage medium impossible without impairing the device's / system's ability to function.

i. The Contractor shall have an existing BAA, Data Use Agreement (DUA), or other agreement in place with VA permitting it to receive the device / system with its data storage medium containing VA sensitive information still intact; or

ii. The Contractor shall, to the greatest extent possible which does not negatively impact operation of the device / system, use a VA-approved method to non-destructively sanitize all data from every hard drive, Complementary Metal-Oxide-Semiconductor (CMOS), Programmable Read-Only Memory (PROM), solid state device, and firmware within the device / system. Selective clearing down to patient data folder level is recommended using VA-approved and validated overwriting technologies / methods / tools. Applicable media sanitization specifications need to be defined and described by the VA Program Office and directly included in the solicitation, contract, or order.

m. DATA CENTER PROVISIONS

1) The Contractor shall ensure that the VA network is accessed in accordance with VA Directive 6500, VA Handbook 6500, and VA Handbook 6510.

2) The Contractor shall ensure the availability of the VA network infrastructure and data in accordance with VA information system business continuity procedures specified in the VA OIS Knowledge Service.

3) The Contractor shall ensure any connections to the internet or other external networks for information systems occur through managed interfaces utilizing VA-approved boundary protection devices (e.g., internet proxies, gateways, routers, firewalls, guards, encrypted tunnels).

4) The Contractor shall encrypt all traffic across the segment of the Wide Area Network (WAN) it manages, and no unencrypted Out of Band (OOB) Internet Protocol (IP) traffic will traverse the network.

5) The Contractor shall ensure tunnel endpoints are routable addresses at each VA operating site.

6) The Contractor shall secure access from Local Area Networks (LANs) at co-located sites in accordance with VA TIC Reference Architecture, VA Directive 6513, VA Handbook 6513, and MOU / ISA process specified in the VA OIS Knowledge Service.

7) Contractor represents and warrants that it will maintain, and ensures its permitted third-parties will maintain, the physical security of any facilities owned, managed, licensed, or controlled by Contractor that store Device Data that does not reside on the Devices' end points by implementing industry best security practices at the locations where the Device Data is stored in order to ensure the confidentiality, integrity, and availability of the Device Data and the systems that store the Device Data.

8) Prior to any change in any Service Location including but not limited to any change in a hosting, data center, and co-location facility or provider, the Contractor will provide written notice and an opportunity for the CO to review a proposed new facility and / or provider, and / or to conduct a Security Assessment.

DRAFT